

Warsaw, December 18, 2024

Decision

DKN.5112.14.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572) and Article 7 paragraphs 1 and 2, Article 60, Article 90, Article 101, and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Article 57 paragraph 1 letters a) and h), Article 58 paragraph 2 letter i), Article 83 paragraphs 1–3 and Article 83 paragraph 4 letter a) in connection with Article 30 paragraph 1, Article 35 paragraphs 1 and 7, and Article 38 paragraph 3 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, as amended), hereinafter referred to as the "Regulation 2016/679", after conducting administrative proceedings initiated ex officio regarding the violation of personal data protection regulations by C. S.A. based in D. at ul. (...), the President of the Personal Data Protection Office¹) finds that C. S.A. based in D. at ul. (...) violated Article 38 paragraph 3 of Regulation 2016/679 by failing to ensure that the data protection officer was directly subordinate to the highest management of the controller and did not receive instructions regarding the performance of their tasks, imposes on C. S.A. based in D. at ul. (...),

an administrative fine in the amount of 261,918.00 PLN (in words: two hundred sixty-one thousand nine hundred eighteen zlotys);

2) finding that C. S.A. based in D. at ul. (...) violated the provisions:

a) Article 30 paragraph 1 of Regulation 2016/679, consisting of failing to take profiling into account in the description of processing operations contained in the processing activities register maintained by C. S.A.;

b) Article 35 paragraphs 1 and 7 of Regulation 2016/679, consisting of failing to conduct an assessment of the impact on the protection of personal data regarding processing operations involving profiling of data, imposes on C. S.A. based in D. at ul. (...), an administrative fine in the amount of 314,302.00 PLN (in words: three hundred fourteen thousand three hundred two zlotys).

Justification

The President of the Personal Data Protection Office, hereinafter referred to as the "President of UODO", based on Article 78 paragraph 1, Article 79 paragraph 1 point 1, and Article 84 paragraph 1 points 1–4 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the "Act", in connection with Article 57 paragraph 1 letters a) and h) and Article 58 paragraph 1 letters b) and e) of Regulation 2016/679, in order to control compliance of data processing with personal data protection regulations, conducted control activities at C. S.A. based in D. at ul. (...), hereinafter referred to as "C. S.A." (case reference: DKN (...)).

The President of UODO conducted control activities at C. S.A. from (...) to (...). The scope of the control included the processing of personal data of clients and potential clients of C. S.A. in connection with their profiling, by determining, among other things:

1) The scope and type of processed personal data.

2) The purpose and duration of personal data processing.

3) Whether C. S.A. has developed procedures regarding profiling.

4) Whether C. S.A. makes decisions based on automated processing, including profiling, of personal data—also constituting banking secrecy—provided that the person affected by the decision made in an automated manner has the right to receive appropriate explanations regarding the basis of the decision made, to obtain human intervention for the purpose of making a new decision, and to express their own position, in accordance with Article 105a paragraph 1a of the Act of August 29, 1997, Banking Law (Journal of Laws of 2024, item 1646).

5) Whether C. S.A. appointed a data protection officer (Article 37 of Regulation 2016/679).

6) Whether C. S.A. maintains a register of processing activities and whether it includes activities involving the profiling of personal data (Article 30 paragraph 1 of Regulation 2016/679).

7) Whether C. S.A. conducts an assessment of the impact on the protection of personal data referred to in Article 35 of Regulation 2016/679, particularly regarding processing operations involving profiling of data.

8) The principles of operation of the information systems used for processing personal data, particularly their profiling.

The factual state established by the controllers of the Personal Data Protection Office was described in the control protocol, which was signed by the person authorized to represent C. S.A. Based on the evidence gathered during the conducted control, the President of UODO made the following findings regarding the factual state:

I. Factual State.

1. C. S.A. processes personal data, including profiling them, also in connection with automated decision-making related to the consideration of credit applications submitted by potential clients or clients of C. S.A. and entering into agreements regarding the provision of credit services by C. S.A. The profiling of data of clients and potential clients of C. S.A. occurs solely for the purpose of determining their creditworthiness. 2. C. S.A. also conducts an assessment of the risk of money laundering and the application of security measures in the R system. 3. C. S.A. processes data of potential clients and clients in the following scope: first name, last name, residential and correspondence address, PESEL number, date of birth, email address, phone number, designation of the country of tax residence, marital status, gender, number of children and their dates of birth, series and number of identity document, source of origin of assets, citizenship, employer's address data, data on credit obligations. In the scope of data obtained as a result of profiling, C. S.A. processes such data as: scoring result, i.e., credit risk score and risk category defined by C. S.A. 4. As of the date of the inspection by the President of UODO, the function of the Data Protection Officer (hereinafter: DPO) in C. S.A. was held by Mr. SJ. The indicated person has held the position since June 24, 2020, based on the resolution of the Management Board of C. S.A. no. (...)/(...). While holding the aforementioned position, SJ was not directly subordinate to the management of C. S.A., which constitutes the "highest management of the controller" within the meaning of Article 38(3) of Regulation 2016/679. The content of the employment contract concluded on September 14, 2017, with C. S.A. by the person holding the position of DPO SJ at the time of the inspection indicates that he was initially employed in the position of (...) and subsequently, by virtue of annex no. (...) dated March 25, 2020, in the position of specialist in (...) in the Team for (...), and later in the Department of (...) C. S.A. 5. The content of the job description attached to the aforementioned employment contract for the position of specialist in (...) in the Department of (...) C. S.A. indicates that the DPO SJ, simultaneously employed as a specialist in (...) in the Team for (...) (later the Department of (...)), "reports to" the Director of the Department of (...), to whom he is subordinate in a professional capacity. In the opinion of the President of UODO, there is no doubt that the obligation of "reporting," included in the job description of SJ in the Department of (...), confirms the direct professional subordination of SJ, who held the position of DPO in C. S.A. at the time of the inspection, to the Director of the aforementioned department. It also follows that SJ was directly subordinate to the Director of the Department of (...) also in the scope of his function as DPO, especially since the Director of the aforementioned Department, due to his tasks, also performed duties related to managing (creating) data processing processes in C. S.A. In this situation, there is no doubt that the subject of "reporting" by SJ to the Director of the Department of (...) also included issues inherently related to the processes of personal data processing by C. S.A. 6. According to the content of § (...) C. S.A., it is the Director of the Department of (...) who is directly subordinate to the "highest management of the controller," referred to in Article 38(3) of Regulation 2016/679 (thus in the case of C. S.A. – the management), and not the specialist in (...), who, according to the content of the aforementioned employment contract and the organizational regulations of C. S.A., is directly subordinate to the Director of the Department of (...). Furthermore, according to (...) C. S.A., the scope of tasks of the Department of (...) includes, among others, the creation, updating, and implementation of the Policy (...) of C. S.A., (...) etc. 7. In turn, according to § (...) of the Policy (...) in force at C. S.A. as of the date of the inspection by the President of UODO, Mr. SJ as the Data Protection Officer was

directly subordinate in the organization of C. S.A. to the member of the management board responsible for the area of personal data protection, i.e., Ms. PK, who held the position of a member of the management board responsible for (...) as of the date of the inspection. 8. The scope of basic duties of SJ as a specialist in (...) included creating and implementing procedures and policies regarding (...) in C. S.A., monitoring the application of the aforementioned procedures and policies, as well as defining requirements regarding (...) in the IT systems of C. S.A. and functioning processes in C. S.A. in this regard. In turn, the scope of the most important duties of SJ as the Data Protection Officer included conducting employee training, participating in legislative processes due to issues of personal data protection, supporting the implementation of technical and organizational measures aimed at ensuring the security of personal data, handling personal data breaches, conducting external correspondence regarding personal data, including in the scope of exercising the rights of data subjects. 9. According to the content of the resolution of the Management Board of C. S.A. no. (...)/(...) dated June 24, 2020, Mr. KN was appointed as the deputy DPO, employed at the time of the inspection in the position of Director of the Department of (...) based on the employment contract dated March 15, 2021, along with annex no. (...) dated December 20, 2021. KN, as the Director of the Department of (...), was the superior of SJ in the scope of duties performed by him within the framework of the position of specialist in (...) in the aforementioned organizational unit of C. S.A. 10. In C. S.A., a register of processing activities is maintained, which specifies: the set of personal data, the processing activity, the form of data processing, the data controller, the purposes of processing personal data in the set/within the processing activities, information fields/scope of data, a description of the categories of persons whose data are processed, categories of personal data, the source of personal data, the legal basis for processing data in the set within the processing activities, IT systems used for processing personal data, the expected date of deletion or storage of individual categories of data, a general description of technical and organizational security measures, categories of recipients to whom personal data have been or will be disclosed (including recipients in third countries) and the name of the third country/documentation of appropriate safeguards. In the aforementioned register, as of the date of the inspection, the activities related to the profiling of personal data were not separately included. 11. In C. S.A., an assessment of the impact on data protection was conducted for the process of credit assessment of clients applying for products. credit (car loan, credit card, credit line, loan) offered by C. S.A. for individual clients. At C. S.A., an assessment of the impact on personal data protection was not conducted separately regarding the processing activities involving profiling of data.

In connection with the above findings, the President of the Personal Data Protection Office (UODO) on August 4, 2023, initiated ex officio administrative proceedings regarding the possibility of a violation by C. S.A., as the administrator, of the obligations arising from the provisions of Article 30(1), Article 35(1) and (7), and Article 38(3) of Regulation 2016/679.

In response, C. S.A. in a letter dated August 22, 2023, addressed in writing the identified violations of personal data protection regulations that are the subject of the administrative proceedings mentioned in the notification of the initiation of the proceedings, indicating that, in its opinion, the Data Protection Officer (DPO) acting as the IOD was directly subordinate within the organization of C. S.A. to a member of the management board of C. S.A. responsible for the area of personal data protection, i.e., PK, who served as a member of the management board responsible for (...). C. S.A. indicated that the position of the IOD in the Department (...) "has only an administrative dimension, i.e., it relates solely to employee matters (e.g., approval of leave) and payroll matters (determination of financial conditions)." Furthermore, C. S.A. explained that the IOD is an independent entity in the performance of its functions. As evidence of the above, C. S.A. attached to its explanations a printout of email correspondence between the IOD and a member of the management board of C. S.A. regarding the approval of the control plan and the report for the previous year on its execution, which, in the opinion of C. S.A., indicates the actual subordination of the IOD directly to a member of the management board of C. S.A.

C. S.A. also indicated that to avoid any doubts, it initiated a process to change the classification of the

IOD within the structures of C. S.A. by placing the Data Protection Inspector directly under a member of the management board. Subsequently, in a letter dated November 29, 2023, C. S.A. explained that it changed the content of the organizational regulations and the organizational structure in such a way that the position of the IOD was separated within the organizational structure of C. S.A. C. S.A. indicated that after the changes, the position of the IOD was organizationally subordinated directly to a member of the management board of C. S.A.

C. S.A. also stated in its letter dated August 22, 2023, that considering the results of the audit regarding personal data protection conducted by an external company, even before the inspection carried out by the supervisory authority in May 2022, it began working on changing the method of recording processing activities in the register of processing activities from business operational processes to individual types of personal data processing activities in C. S.A. C. S.A. stated that "the currently applicable (...) register of processing activities describes individual processing activities carried out in C. S.A., including profiling." Additionally, C. S.A. attached to the explanations contained in the letter dated August 22, 2023, the currently applicable register of processing activities, which included the processing activity in the form of data profiling within the assessment of creditworthiness (scoring) of C. S.A. clients.

In the letter dated August 22, 2023, C. S.A. also explained that the assessment of the impact of planned processing operations provided during the inspection concerned the credit assessment process, of which scoring is an inseparable element, meaning the evaluation of the client based on criteria defined by C. S.A. In the opinion of C. S.A., the aforementioned assessment "can be qualified as profiling," even though the functional description of the creditworthiness assessment in the impact assessment does not contain the term "profiling." C. S.A. raised that it took into account scoring and its result as a factor subject to the assessment of the impact on data protection in the credit assessment process, i.e., internal documentation, procedure (...), and the procedure "Policy (...)." Additionally, reference was made to the "Procedure (...)." At the same time, C. S.A. indicated in its letter dated August 22, 2023, that "in response to the comments of the President of UODO indicated in the letter dated August 4, 2023," C. S.A. detailed the content of the impact assessment concerning processing operations related to creditworthiness assessment (including the scoring process) by explicitly indicating the activity in the form of profiling. C. S.A. attached to the letter a printout of the modified content of the impact assessment description.

II. In this factual state, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

II.1. Violation of Article 38(3) of Regulation 2016/679. According to Article 38(3) of Regulation 2016/679, the administrator and the processor ensure that the data protection officer does not receive instructions regarding the performance of these tasks. He is not dismissed or penalized by the administrator or the processor for fulfilling his tasks. The data protection officer is directly accountable to the highest management of the administrator or the processor.

During the inspection activities, it was established that C. S.A., contrary to the provisions of Article 38(3) of Regulation 2016/679, did not implement organizational measures to ensure that the IOD was directly accountable to the highest management of the administrator and did not receive instructions regarding the performance of his tasks. The gathered evidence clearly indicates that in the internal documentation, it included organizational solutions that do not meet the requirements specified in the aforementioned provision of Regulation 2016/679 (employment contract dated September 14, 2017, along with an annex, organizational regulations before the amendment after the inspection by the President of UODO).

Thus, considering the fact that the data protection officer was employed on the day of the inspection in the Department (...) of C. S.A. as a specialist in (...) and was executing orders from his direct superior, i.e., the Director of the aforementioned Department, who is not a member of the "senior management of the administrator," it must be stated that C. S.A. violated Article 38(3) of Regulation 2016/679. The violation of the aforementioned provision also arises from the fact that C. S.A., as the administrator, did not ensure, in light of the factual state established above (described in points 5-9), that the data

protection officer did not receive instructions regarding the performance of these tasks. It must be recognized that the full subordination of the data protection officer to the Director of the Department (...) excludes the possibility of ensuring that the officer does not receive instructions regarding the performance of his tasks, especially since the department in which he worked was substantively responsible for issues that also fall within the scope of the data protection officer's duties, namely primarily for information security at C. S.A.

Taking the above into account, it must be stated that, from a logical point of view, it is not possible for the data protection officer, working in the organizational unit of C. S.A. responsible for information security, and thus personal data, not to receive orders from the head of that unit, also in the substantive area covering issues for which that officer is responsible. For this reason, the explanations provided by C. S.A. regarding the alleged factual subordination of the data protection officer directly to a member of the management board of C. S.A., supported by individual emails exchanged between these individuals, are unconvincing.

It should be noted that by Resolution No. (...) / (...) of the Management Board of C. S.A., a deputy data protection officer was appointed, employed on the day of the inspection as the Director of the Department (...) of C. S.A. and simultaneously being the direct superior of SJ, the data protection officer of C. S.A., employed in the aforementioned department as a specialist in (...). The situation described above should also be assessed as a violation of the provisions of Article 38(3) of Regulation 2016/679, as it is difficult to accept that the data protection officer of C. S.A., in a situation where a person who is also his direct superior has been appointed as his deputy, does not receive instructions regarding the performance of tasks from the Director of the Department (...).

In light of the above, once again, the explanations provided by C. S.A. in this regard, contained in the letter dated August 4, 2023, addressed to the President of the UODO, in which C. S.A. referred, among other things, to the attached electronic correspondence indicating, in its opinion, the actual independence of the data protection officer, despite his formal employment in the organization of C. S.A. as subordinate to the Director of the Department (...), should be considered unreliable. Referring to these explanations, it must be stated that the aforementioned correspondence cannot be regarded as evidence of the data protection officer being directly subordinate to the senior management of C. S.A., since the content of all documents, starting from the employment contracts concluded with C. S.A. by SJ, who held the position of data protection officer on the day of the inspection, and KN, employed as the Director of the Department (...), and ending with the internal procedures of C. S.A. and its organizational chart, indicates the subordination of the data protection officer to a person who is not a member of the management board of C. S.A.

It must therefore be stated that the explanations provided by C. S.A. in this regard do not bring anything new to the case and do not constitute an argument against the accusation made by the President of the UODO regarding the data protection officer's lack of subordination to the senior management of C. S.A.

It should be emphasized that the appointment of SJ to perform the function of the data protection officer under the aforementioned factual circumstances, and primarily due to the fact that he was employed in the Department (...) and made subordinate to the director of that unit, contradicts the written post-inspection explanations of C. S.A. regarding the "actual" independence of the data protection officer and subordination solely to the management of C. S.A., as well as the content of § (...) of the Policy (...) in force at C. S.A. on the day of the inspection, according to which SJ, as the data protection officer, was to be subordinate in the organization of C. S.A. directly to the member of the management board responsible for the area of personal data protection. This means that the Policy (...), in light of the circumstances indicated above and the manner of employing the data protection officer in C. S.A., was not implemented in this regard, which means that C. S.A. did not meet the requirements of Article 38(3) of Regulation 2016/679.

C. S.A. argues in its explanations that SJ was subordinate to the Director of the Department (...) only "organizationally," but in performing the duties of the data protection officer, he was "actually"

subordinate solely to a member of the management board of C. S.A. However, the explanations provided by C. S.A. cannot be considered reliable and substantive. The regulation adopted by C. S.A. in § (...) of the Policy (...) cannot merely be a declaration that is not supported by the actual state of affairs established during the inspection. Therefore, if the aforementioned regulation adopts the principle that the data protection officer is directly subordinate to a member of the management board responsible for the area of data protection, then consistent actions must be implemented to confirm this declaration. The circumstances of SJ's employment by C. S.A., i.e., his employment in the Department (...) as subordinate to the director of that unit and the appointment of the latter to perform the function of deputy SJ as the data protection officer, as well as the substantive scope of tasks performed by the Department (...), contradict the provision of § (...) of the Policy (...) in force at C. S.A., according to which the data protection officer is directly subordinate to a member of the management board.

In other words, it cannot happen, as in the present case, that the administrator, i.e., C. S.A., introduces certain organizational measures, such as the policy (...), in which it declares the independence of the data protection officer in performing his duties, including his subordination solely and directly to the senior management (i.e., in this case, the management board).

C. S.A.), and at the same time, it actually applies organizational and legal solutions, such as employment contracts along with the specification of duties therein, which indicate that they are in contradiction with the provisions of the policy, and consequently with the content of Article 38(3) of Regulation 2016/679. It should be recalled that in this case, in contradiction with the requirements of § (...) of the Policy (...) and Article 38(3) of Regulation 2016/679 is the content of the employment contract concluded with SJ on September 14, 2017, under which he was first employed in the position of (...), then, by virtue of annex no. (...) dated March 25, 2020, in the position of specialist in (...), and subsequently – as of the date of the inspection – in the Department of (...) C. S.A. The content of the job description attached to the aforementioned employment contract for the position of specialist in (...) in the Department of (...) C. S.A. indicates that the person acting as the DPO SJ, simultaneously employed as a specialist in (...) in the Team for (...) (later Department of (...)), "reports to" the Director of the Department (...), to whom he is subordinate. The above designation indicates that the aforementioned person was obliged to provide the Director of the Department (...) with information about the tasks performed by him, including those related to the performance of his function as a data protection officer. From the entirety of the duties performed by SJ and the Director of the Department (...) as of the date of the inspection and the tasks of the aforementioned department, it follows unequivocally that his director was also responsible for the sphere of data processing processes occurring in C. S.A. This is related to the fact that the subordinate to the Director of the Department (...) SJ, performing the function of DPO, necessarily had to be subordinate to him also in the scope of performing that function. Such a situation completely excludes the fulfillment of the requirement of the DPO being subordinate to the highest management of the administrator, in accordance with Article 38(3) of Regulation 2016/679.

It should also be noted that C. S.A., appointing SJ to perform the function of DPO and simultaneously employing him in the position of specialist in (...) in the Department (...) as a subordinate of the director of this unit and appointing the aforementioned director to perform the function of SJ's deputy as DPO, did not comply with the provisions of the policy (...), which it was obliged to follow under Article 24(1) and (2) of Regulation 2016/679, according to which, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons of varying likelihood and severity of the threat, the administrator implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary (paragraph 1). If it is proportionate in relation to the processing activities, the measures referred to in paragraph 1 include the implementation by the administrator of appropriate data protection policies (paragraph 2).

Considering all the circumstances of the case mentioned above, and above all the formal organization

of SJ's work (including when performing DPO duties), the substantive scope of his duties as DPO and specialist in (...) in the Department (...) and the scope of tasks of the Department (...) C. S.A., and also referring finally to life experience in similar situations, it must be stated that the explanations of C. S.A., in which it argues that in fact SJ in the scope of performing DPO duties was directly and exclusively subordinate to a member of the management board, are unconvincing and do not find support in the established factual state. In this situation, the provisions of the employment contract concluded with C. S.A. by the person performing the function of DPO SJ as of the date of the inspection were in contradiction with the content of § (...) of the Policy (...) and Article 38(3) of Regulation 2016/679, causing that he was both formally and factually, directly subordinate to a person not belonging to the highest management of C. S.A. (the Director of the Department (...)).

In connection with the above, C. S.A. cannot argue that the above-described state is in accordance with the requirements of Article 38(3) of Regulation 2016/679 and § (...) of the Policy (...), because, according to C. S.A., it is a "formal" solution, not a factual one. The President of the UODO cannot therefore accept C. S.A.'s explanation as credible, that the evidence of the DPO being subordinate to the highest management of C. S.A. as the administrator is the declaration of the latter that, although formally, inter alia, based on the employment contract, SJ was subordinate to the Director of the Department (...), in fact, C. S.A. "did not fully utilize" the formal provisions of this contract and de facto SJ as DPO was directly and exclusively subordinate to the management of C. S.A. The contradiction between the provisions of the employment contract and the provision of Article 38(3) of Regulation 2016/679 and § (...) of the Policy (...) of C. S.A. determines that the President of the UODO must conclude that C. S.A. did not ensure that the DPO was directly subordinate to the highest management of C. S.A. as the administrator. The subordination of C. S.A. to the Director of the Department (...), i.e., an internal unit of C. S.A., whose tasks also included activities related to the sphere of information security in C. S.A., and thus the protection of personal data, is also equivalent to the fact that SJ, contrary to the requirement of Article 38(3) of Regulation 2016/679, received instructions regarding the performance of DPO tasks from the Director of the Department (...). The aforementioned subordination, by the nature of the employment relationship, in which the employee is obliged to follow the orders of the superior, determines that SJ received instructions that are also significant for the manner in which he performed the function of DPO in C. S.A. To confirm the above reasoning, reference should be made to the content of the Guidelines of the Article 29 Working Party on Data Protection regarding data protection officers ("DPO"), amended and adopted on April 5, 2017. According to the content of the aforementioned document, "The administrator and the processor are responsible for complying with data protection regulations and must be able to demonstrate compliance."

In the event that the administrator or the processor makes a decision that is inconsistent with the provisions of the GDPR and the recommendations of the DPO (i.e., the Data Protection Officer – note from the President of the UODO), the DPO should have the opportunity to clearly present their separate opinion to the highest management and decision-makers. Article 38(3) states that This direct reporting ensures that the highest management (e.g., members of the board) is informed about the advice and recommendations of the DPO in the context of the DPO's task of informing and advising the administrator or the processor. Another example of direct reporting is the preparation of an annual report for the highest management regarding the activities conducted by the DPO.

II.2. Violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679.

1. According to Article 30(1) of Regulation 2016/679, each administrator and, where applicable, the representative of the administrator shall maintain a record of processing activities for which they are responsible. This record shall include all of the following information: a) the name and contact details of the administrator and any co-administrators, as well as, where applicable, the representative of the administrator and the Data Protection Officer; b) the purposes of the processing; c) a description of the categories of data subjects and the categories of personal data; d) the categories of recipients to whom the personal data have been or will be disclosed, including recipients in third countries or international organizations; e) where applicable, the transfer of personal data to a third country or an

international organization, including the name of that third country or international organization, and in the case of transfers referred to in Article 49(1) second paragraph, documentation of the appropriate safeguards; f) if possible, the planned time limits for erasure of the different categories of data; g) if possible, a general description of the technical and organizational security measures referred to in Article 32(1).

In light of the above, the violation by C. S.A. of Article 30(1) of Regulation 2016/679 arises from the fact established during the inspection and proceedings that C. S.A. does maintain the aforementioned record; however, it does not include in the description of the processes (activities) the processing of data related to their profiling. This fact was confirmed by C. S.A. in the explanations provided during the inspection, indicating that the record of processing activities records products, not activities or processes on personal data, while profiling is an element of providing a credit product, which is included in the record of processing activities. Similar explanations were provided by C. S.A. in the letter dated August 4, 2023, addressed to the President of the UODO following the inspection.

However, it should be noted that profiling, as defined in Article 4(4) of Regulation 2016/679, is a specific form of automated processing of data, as a result of which personal data – in the case of C. S.A. – are used to assess the economic situation of individuals, i.e., its clients. It should be noted that the record of processing activities is a document that should transparently, specifically, and exhaustively describe the data processing processes occurring at the administrator. The lack of the aforementioned characteristics in the record of processing activities renders it ineffective, and even useless, considering that its content is intended to serve, among other things, the supervisory authority, in the event of its inspection, to obtain information regarding the processing processes actually occurring at the controlled administrator without leaving any doubt.

Therefore, it should be indicated that C. S.A. should have included profiling in the record of processing activities it maintains as a specific form and, at the same time, an essential stage of processing customer data in the broadly understood process of granting them loans. The description of the processing activities related to profiling should be included in the record of processing activities due to the specificity of profiling in data processing, i.e., the use of automated technical devices (means) and the creation of new information about individuals, including those whose disclosure could lead to negative consequences for them (such as stigmatization, discrimination related to the potential availability of information about the financial status, i.e., the creditworthiness of C. S.A. clients to unauthorized persons). This, in turn, is of significant importance due to the potential risk of violating the rights or freedoms of data subjects.

For the reasons indicated above, the clear demonstration in the content of the record of processing activities of the activities involving the profiling of C. S.A. clients' data serves data security and is necessary to ensure the transparency and specificity of this document. The aforementioned view is also confirmed in the literature on the subject. As A. Mednis points out, "It should therefore be accepted that activities are distinguished by the purposes of processing. At the same time, according to the guidelines of the GIODO, in cases of significant differences in the other criteria listed in Article 30(1) of the GDPR, activities serving the same purpose but differing in terms of the categories of data subjects, categories of data, and methods of processing should be distinguished. This is particularly important in the case of profiling and making automated decisions. The exceptional nature of both actions and their specification in the GDPR means that they should be distinguished in the record."

In this situation, the lack of distinction by C. S.A. of profiling in the content of the record of processing activities constitutes a violation of Article 30(1).

1 Regulation 2016/679. 2. According to Article 35(1) of Regulation 2016/679, if a specific type of processing—particularly using new technologies—due to its nature, scope, context, and purposes is likely to result in a high risk to the rights or freedoms of natural persons, the controller shall, prior to processing, carry out an assessment of the impact of the planned processing operations on the protection of personal data. For similar data processing operations involving a similar high risk, a single assessment may be conducted. Furthermore, according to Article 35(7) of Regulation 2016/679, the aforementioned assessment shall include at least: a) a systematic description of the planned

processing operations and the purposes of the processing, including, where applicable, the legitimate interests pursued by the controller; b) an assessment of whether the processing operations are necessary and proportionate to the purposes; c) an assessment of the risks to the rights or freedoms of data subjects referred to in paragraph 1; and d) the measures planned to address the risks, including safeguards and security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of data subjects and other persons concerned.

As established during the inspection, C. S.A. did not carry out an assessment of the impact on the protection of personal data concerning the data processing activities in the form of profiling. Considering the above, it should be stated that the lack of an assessment of the impact on the protection of data related to the profiling of customer data by C. S.A. constitutes a violation of Article 35(1) and (7) of Regulation 2016/679. Furthermore, the assessment of the planned processing operations of personal data by C. S.A., submitted during the inspection, does not meet the requirement contained in Article 35(7)(a) of Regulation 2016/679, i.e., it does not include in the systematic description of the planned processing operation in the form of profiling data for the purpose of determining the creditworthiness of C. S.A. customers.

It should be noted that profiling as a form of data processing indicated in Article 4(4) of Regulation 2016/679, particularly in the case of entities such as C. S.A. and the circumstances of data processing, should be clearly included in the content of the impact assessment due to the aforementioned specificity of profiling in data processing and the associated risks, i.e., the use of automated technical devices (means) and the creation of new information about natural persons, including information whose disclosure could lead to negative consequences for them (stigma, discrimination related to the potential availability of information about the financial status, i.e., the creditworthiness of C. S.A. customers).

Therefore, due to the threats associated with data processing through profiling and the risk of violation of the rights or freedoms of data subjects, a clear demonstration of profiling within the risk analysis and the content of the impact assessment for processing is essential to ensure the security of that data. Although, as evidenced by the evidence collected during the inspection, C. S.A. does not make automated decisions regarding the granting of credit, which, in light of the wording of Article 35(3)(a) of Regulation 2016/679, which expands the provisions of Article 35(1), would explicitly require it to prepare an impact assessment regarding profiling activities, it should be noted that the catalog of cases indicated in the aforementioned provision, in which the controller is obliged to carry out an assessment of the impact on the protection of data, is not closed, which means that this provision does not exclude that the performance of the subject assessment is also mandatory in other cases.

The aforementioned issue is also addressed on page 8 of the Guidelines of the Article 29 Working Party (WP251rev.01) regarding automated decision-making in individual cases and profiling for the purposes of Regulation 2016/679, adopted on October 3, 2017, last amended and adopted on February 6, 2018, by stating that “Decisions that are not solely automated may also involve profiling. For example, before granting a mortgage loan, a bank may take into account the credit scoring of the borrower, while before making any decision regarding a natural person, there is still human intervention.”

Moreover, on page 29 of the aforementioned Guidelines, the Article 29 Working Party states that “Article 35(3)(a) refers to assessments that include profiling and decisions ‘based’ on automated processing, and not ‘exclusively’ on automated processing. In the opinion of the Article 29 Working Party, Article 35(3)(a) will apply in cases of decision-making, including profiling, which have legal effects or similarly significantly affect the data subject, which is not fully based on automated processing, as well as decision-making based on automated processing as specified in Article 22(1). (...) The controller can still foresee a ‘model’ of decision-making based on profiling significantly increasing the level of human intervention, so that the model is no longer a fully automated decision-making process, although the processing may still pose risks to the fundamental rights and freedoms of natural persons. In such a case, the controller must ensure that it is able to address these

risks and meet the requirements described in Chapter III of these Guidelines.”

In the opinion of the President of the Personal Data Protection Office (UODO), the profiling practiced by C. S.A. is a case where, even due to the large scale of this activity, its scope,

****Context and Objectives****

should be subject to an assessment of the impact on data protection. As indicated in the literature on the subject[3], "the cited provision (Article 35(3) of Regulation 2016/679 – note from the President of the UODO) implies an obligation to conduct an assessment if we are dealing with a sequence of ; however, this does not mean that profiling itself (i.e., when its effect does not result in automated decisions) is not subject to assessment. It is subject to assessment under the general principles expressed in Article 35(1) of the GDPR, and thus if Stage 1 (i.e., risk analysis – note from the President of the UODO) confirms a high probability of infringement of rights and freedoms as a result of the planned profiling. The operations listed in Article 35(3) of the GDPR should be treated as examples. This is confirmed by the WP 248 Guidelines (Article 29 Working Party – note from the President of the UODO): .

Among the criteria for recognizing risk as high, the WP 248 Guidelines mention evaluation or scoring, including profiling and forecasting, particularly based on (recitals 71 and 91 of the GDPR preamble). The Article 29 Working Party cites as an example a financial institution checking its clients against a reference credit database or a database for combating money laundering and terrorist financing or in a database containing information about financial abuses.

It should also be noted that in the Communication from the President of the Personal Data Protection Office dated June 7, 2019, regarding the list of types of personal data processing operations requiring an assessment of the impact of processing on their protection (M.P. of July 8, 2019, item 666), issued under Article 54(1)(1) of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781) in connection with Article 35(4) and (6) of Regulation 2016/679, the President of the UODO indicated, among other things, as operations requiring an assessment of the impact of processing: evaluation or assessment, including profiling and forecasting (behavioral analysis) for purposes causing negative legal, physical, financial, or other inconveniences for individuals, conducted by "banks, other financial institutions authorized to grant loans, lending institutions in the process of assessing creditworthiness."

In light of the above, it should be noted that C. S.A., having not considered profiling as a separate activity in its risk analysis and also in the assessment of the impact on data processing, violated Article 35(1) and (7) of Regulation 2016/679.

It should be emphasized that the explanation provided by C. S.A. in the letter dated August 4, 2023, that the impact assessment conducted by C. S.A. as of the date of the inspection also refers to profiling, despite the functional description of creditworthiness assessment in the impact assessment not containing the term "profiling," does not merit consideration. This argument from C. S.A., in light of the above reasoning contained in the justification of this decision, cannot be accepted. The content of the document containing the impact assessment for the processing activities should be clear and transparent, and the supervisory authority, when conducting control activities, should not be forced to "guess" what content lies behind the description of the aforementioned assessment. The specificity of the profiling process, in light of the above remarks, the WP 248 Guidelines of the Article 29 Working Party, the communication from the President of the UODO dated June 7, 2019, and the cited literature on the subject, imposes on the controller the requirement to treat this form of processing in a clear and specific manner when formulating the associated risks, and consequently the impacts on processing. Therefore, formulating risks and impacts collectively for the entire service process, in principle, may be correct and compliant with the provisions of Regulation 2016/679; however, in the case of profiling operations related to the granting of loans by C. S.A., due to the specificity described above, it is an action inconsistent with Article 35(1) and (7) of Regulation 2016/679, as it "blurs" the actual risks and impacts associated with profiling, camouflaging them behind a general description of the credit service.

****III. Behaviors Subject to Administrative Monetary Penalties****

The administrative proceedings conducted by the President of the UODO serve to monitor compliance of data processing with the provisions on personal data protection and are aimed at issuing an administrative decision to apply the corrective powers specified in Article 58(2) of Regulation 2016/679.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of the measures referred to in Article 58(2) of Regulation 2016/679, an administrative monetary penalty under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the identified violations of the provisions of Regulation 2016/679, the President of the UODO, exercising the power granted to him under the aforementioned provision, determined that in the case at hand, there were grounds justifying the imposition of an administrative monetary penalty on the Company. Accordingly, pursuant to the provisions of Article 83(2) of Regulation 2016/679, administrative monetary penalties are imposed, depending on... of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a)-(h) and (j) of Regulation 2016/679. According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions shaping the obligations of the controller and the processor, as referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, in accordance with paragraph 2, to an administrative fine of up to EUR 10,000,000, and in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. It should be noted that the President of the UODO, when imposing an administrative fine in this case for the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 (unrelated to the violation of Article 38(3) of Regulation 2016/679), also took into account the content of Article 83(3) of Regulation 2016/679, according to which if the controller or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative fine does not exceed the amount of the fine for the most serious violation.

In connection with the finding of violations of three provisions of Regulation 2016/679 (Article 30(1), Article 35(1) and (7), Article 38(3)), the President of the UODO is entitled to apply one or several corrective measures specified in Article 58(2) of Regulation 2016/679. Among these powers of the supervisory authority is the authority to impose, in addition to or instead of other measures referred to in this provision, an administrative fine under Article 83, depending on the circumstances of the specific case. The circumstances of this case, in particular the seriousness of the identified violations, which will be discussed in further parts of the justification, indicate that it will be appropriate and necessary to exercise this power.

The sanction provided by the legislator for violations of the provisions shaping the obligations of the controller (including for violations of the provisions of Article 30(1), Article 35(1) and (7), Article 38(3) of Regulation 2016/679) is – in accordance with Article 83(4)(a) of Regulation 2016/679 – an administrative fine of up to EUR 10,000,000, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. In determining the specific sanctions for the violations identified in this case, the President of the UODO referred to the guidelines contained in the EROD Guidelines 04/2022 on calculating administrative fines based on the GDPR (version 2.1) adopted on May 24, 2023, hereinafter referred to as the "Guidelines 04/2022".

The first step in the methodology for calculating administrative fines adopted there is "to determine the processing operations in the case and assess the application of Article 83(3) of the GDPR" (see paragraph 17 of the Guidelines 04/2022). Expanding on this guidance in paragraph 24 of its guidelines, EROD recommends first determining: a) whether the circumstances indicate a single behavior or multiple behaviors subject to penalties; b) in the case of a single behavior, whether that behavior constitutes a single violation or multiple violations; c) in the case of a single behavior that constitutes multiple violations, whether attributing one violation excludes attributing another violation, or whether they should be attributed concurrently.

The interpretation of the term "single behavior" is contained in – referring to Article 83(3) of Regulation 2016/679, which mentions "the same or related processing operations" – paragraph 28 of the EROD

guidelines. According to it, "[t]he term 'related' refers to the principle that a single behavior may consist of several parts that are carried out as a result of a single act of will and are contextually (especially regarding the identity of the data subject, the purpose, and the nature of the processing), spatially, and temporally so closely related that from an objective point of view they can be considered a single coherent behavior."

Relating the above provisions of Regulation 2016/679 and the guidance contained in the Guidelines 04/2022 to the circumstances of this case, the President of the UODO stated the following:

1. The President of the UODO found that the actions of C. S.A. concerning the profiling of personal data of its current and potential clients (essentially the failure to undertake such actions required by the provisions of Regulation 2016/679) constitute "one coherent behavior" in the sense presented by EROD. The aforementioned behavior consists of: the failure to conduct an assessment of the impact of the profiling operations of personal data of current and future clients of C. S.A. for data protection (constituting a violation of Article 35(1) and (7) of Regulation 2016/679) and the failure to include this type of processing operation in the register of processing activities (constituting a violation of Article 30(1) of Regulation 2016/679). Both of these omissions by C. S.A. are, in the opinion of the President of the UODO, the result of a single act of will by C. S.A. C. S.A. has a priori – as follows from the so-called "product" approach to processing processes in the organization of C. S.A. – assumed that the profiling operation is merely one of the elements of the credit product and one of the types of personal data processing that make up this product (alongside, for example, the operation of acquiring personal data, sharing this personal data with other entities within the banking system, using it for marketing purposes, or finally deleting it). Importantly, C. S.A. – also a priori – recognized (since it refrained from conducting a separate assessment of the impact of profiling on data protection) that this type of processing does not differ from other types of operations.

processing that constitutes a credit product

the level of risk of infringement of the rights or freedoms of individuals

whose data has been subject to profiling.

The fact that the processing operations involving

profiling, which are the subject of both

considered infringements of the provisions of Regulation

2016/679 (Article 30(1) and Article 35(1) and (7)), are

the same operations within the meaning of Article 83(3)

of Regulation 2016/679 is indicated – apart from being

covered by a single act of will of C. S.A. – also by the context

in which they are carried out. They are connected, in the opinion of the President

of UODO: a) the purpose of processing – preparing an assessment

of the creditworthiness of clients or potential

clients of C. S.A., that is, their ability to

meet obligations towards C. S.A.; b) the nature of processing – obtaining personal data

from the data subject, from the banking system and other sources; then combining them

and making assessments of their creditworthiness based on them – in a manner that is almost

entirely automated and remains beyond the control

of the data subjects; c) the level of risk – higher than in the case of other

processing operations carried out within the framework of the credit product – which results from the

aforementioned nature of the profiling operations; d) the identity of the individuals whose data

is being profiled – the processing concerns all

current and potential clients using

the procedures (...) of C. S.A.

Considering therefore that: firstly, the actions of C. S.A.

(his omissions) related to profiling constitute

one coherent behavior (which results from their being

covered by a single act of will and the context of the processing

covered by that act of will), and secondly, this behavior

violates two provisions of Regulation 2016/679 (Article 30(1) and Article 35(1) and (7)), it should be stated that none of these identified infringements excludes attributing the second of them to C. S.A. In particular, none of them constitutes a "qualified type" of the second of these infringements, is not "subordinate" to the second, and does not constitute a form of

staging of the second infringement (preparation, attempt to commit) – see Subsection 3.1.1 of Guidelines 04/2022.

The above results primarily from the fact that the purposes of both infringed provisions are different and the legal interest

that they protect is different. The provision of Article 35(1) of Regulation 2016/679 defines the first – fundamental – step for the administrator to create an effective, adequate to the level of existing risks, system of personal data protection. It aims, therefore – by obliging the administrator to carry out an assessment of the impact of processing on data protection – to ensure directly and immediately appropriate protection of personal data of the individuals concerned. On the other hand, the provision of Article 30(1) of Regulation 2016/679 does not directly relate to the protection of the rights and interests of individuals whose data is processed by the administrator.

Its purpose is to provide the supervisory authority with the information necessary for it to fulfill one of its tasks – the proper assessment of the risks associated with the processing operations carried out by the administrator and the assessment of the adequacy of the security measures implemented by him for data protection.

The above allows for attributing both infringements to C. S.A. "in parallel" – neither of them excludes attributing the second of them to C. S.A. In this situation, the provision of Article 83(3) of Regulation 2016/679 will apply to both of these infringements.

2. The actions of C. S.A. leading to the infringement of Article 38(3) of Regulation 2016/679 do not constitute a single behavior – along with the omissions considered above leading to the infringement of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679. The following circumstances indicate this: a) unlike the behavior of C. S.A. constituting an infringement of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679, its behavior resulting in the infringement of Article 38(3) of Regulation 2016/679

did not consist of an omission but of an action, i.e., the adoption of a resolution by the Management Board of C. S.A. on June 24, 2020,

to appoint an employee of the Department (...) of C. S.A. as the Data Protection Officer (without changing his position in the structure of C. S.A.); b) unlike the behavior of C. S.A.

related to profiling, the actions of C. S.A.

resulting in the infringement of Article 38(3) of Regulation 2016/679 did not directly concern any processing operations carried out in C. S.A.; while it is true that the infringement of the status of the

Data Protection Officer and his independent position relative to the administrator may indirectly negatively affect the proper security of data processing and the proper protection of the rights, freedoms, and interests of individuals whose data is processed, it is not a direct and automatic impact; c) the decision of C. S.A. regarding the placement of the Data Protection Officer in its structure was independent of the act of will of C. S.A. leading to the infringement of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679; it concerned a different area of regulation of Regulation 2016/679 (the purpose and motivation of this behavior were different), and it was also taken in a different temporal context (June 2020, while the omission related to profiling operations had been occurring since January 2019).

At this point, it should be noted that the only reason for which the infringement of Article 38(3) is considered – alongside both previous ones – in one proceeding (and assessed in one decision of the President of UODO) is the circumstance of its identification during the inspection, which aimed – according to the plan of sectoral inspections of the President of UODO for 2022 – to examine in entities of the banking sector "the processing of personal data in the context of profiling personal data of clients and potential clients and the way of informing individuals applying for credit about the credit assessment made." As stated in Guidelines 04/2022, such

a situation excludes the application of the limitation resulting from Article 83(3) of Regulation 2016/679.

total amount of the imposed administrative monetary penalty up to (maximum) the penalty for the most serious violation (see paragraph 45 of the Guidelines 04/2022).

3. Summarizing the above:

a) The President of UODO found in this case two violations committed by C. S.A. – through a single act – of the provisions of Regulation 2016/679 (Article 30(1) and Article 35(1) and (7)). For both of these violations, the provision of Article 83(3) of Regulation 2016/679 was applied, whereby – due to the fact that both violations are (in abstracto) threatened with the same penalty resulting from Article 83(4) of Regulation 2016/679 (up to EUR 10,000,000 or up to 2% of annual turnover) – both violations should be assigned the same severity. Consequently, this means that it is not possible to impose a penalty – for both of these violations – that exceeds the maximum penalty for one of them (EUR 10,000,000 – due to the necessity of adopting the so-called "static maximum penalty" in relation to C. S.A. – see point 5 on pages 38-39 of the justification of this decision).

b) Through a separate act (not concerning the same processing operations and not connected in any way with the processing operations that were the subject of the previous two violations), C. S.A. violated another provision of Regulation 2016/679 – Article 38(3). Due to the distinct nature of C. S.A.'s behavior, the President of UODO did not consider it together with the previous violations and did not take into account the amount of the penalty imposed for it in the total amount of the penalty imposed on C. S.A. for the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679. The provision of Article 83(3) of Regulation 2016/679 does not apply to this violation – as it does not concern in any way the processing operations that are the subject of violations related to the profiling of current and potential customers of C. S.A.

IV.1. Violation of Article 38(3) of Regulation 2016/679 – criteria for the imposition of an administrative monetary penalty (Article 83(2) of Regulation 2016/679).

In connection with the above, when deciding to impose an administrative monetary penalty for the

violation by C. S.A. of Article 38(3) of Regulation 2016/679, the President of UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which constitute the necessity of applying this type of sanction in this case and which have a burdensome effect on the amount of the imposed administrative monetary penalty: a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679) – the nature of the violation is an aggravating circumstance for C. S.A. due to the fact that as a professional entity, a significant part of whose business activity consists of large-scale processing of data associated with a relatively high risk of infringement of the rights or freedoms of data subjects, it was obliged to exercise particular diligence in properly delegating the duties of the Data Protection Officer (DPO). The European legislator included in Article 38(3) of Regulation 2016/679 the obligation for the DPO to report directly to the highest management of the controller, as it recognized that due to the nature and importance of this function for data security, it is significant and requires full substantive independence and a high degree of independence in the organizational hierarchy of the controller. By failing to meet the aforementioned requirement, C. S.A. clearly weakened the security of the processed data and failed to comply with the fundamental obligations of the controller established in the provisions of Regulation 2016/679. The violation of the provisions related to the appointment of the DPO in a manner that does not ensure its direct subordination to the highest management of the controller and the lack of instructions regarding the performance of the DPO's tasks (violation of Article 38(3) of Regulation 2016/679) is of significant weight due to the type of data processed by C. S.A. (e.g., data concerning the financial situation of individuals whose data are concerned, PESEL number, etc.), the manner of processing (use of IT systems, profiling), and the large scale of processing. Ensuring the independence of the DPO in an institution such as C. S.A., considering the above circumstances of processing, i.e., taking into account the nature, scope, and scale of data processing by C. S.A., translates into the security of that data, and consequently into the rights and freedoms of the individuals whose data are processed, including the manner of their realization. It should also be emphasized that the subordination of the DPO directly to the highest management of the controller and the lack of instructions received by him regarding the performance of tasks serves to ensure the independence of the DPO, which is also to be a guarantee of effective and proper execution of the tasks assigned to him in Article 39 of Regulation 2016/679. Additionally, as evidenced by the collected evidence during the inspection conducted against C. S.A., the violation of the provisions of Regulation 2016/679 concerning the Data Protection Officer occurred continuously and intentionally from the date of appointment of SJ by C. S.A. to perform the function of DPO, i.e., from June 24, 2020 (based on the resolution of the Management Board of C. S.A. no. (...)/(...)), at least until August 22, 2023. In the written explanations of C. S.A. dated on the aforementioned day, it informed the President of UODO that changes aimed at rectifying the violation had just been initiated. It should therefore be stated that the violation was prolonged, as it lasted for more than 3 years. The violation of Article 38(3) of Regulation 2016/679 established by this decision remains unaffected by the criterion of the number of affected individuals whose data are concerned, as well as the extent of the damage suffered by them.

damages, as no injured parties were identified in the matter at hand. It should also be noted that the aforementioned violation was not directly related to the processing of personal data by C. S.A., and therefore, no harm to individuals occurred or could have occurred due to the nature of this violation. Nevertheless, given the character, severity, and duration of the aforementioned violation of Regulation 2016/679, this criterion should be assessed as aggravating when considered in its entirety.

b) The intentional nature of the violation of the provisions of Regulation 2016/679 by C. S.A. (Article 83(2)(b) of Regulation 2016/679) – the evidence collected during the inspection and the explanations provided by C. S.A. in the letter dated August 22, 2023, indicate that C. S.A. intentionally appointed the Data Protection Officer (DPO) in a manner that did not ensure their direct subordination to the highest management of the administrator (violation of Article 38(3) of Regulation 2016/679). This action, considering the content of the employment contracts concluded with SJ and KN, bore the hallmarks of intentional conduct, i.e., the circumstances of the case indicate that C. S.A. was aware of the

aforementioned omissions and the potential consequences arising from them, affecting compliance with Article 38(3) of Regulation 2016/679, yet accepted their potential occurrence. It should be noted that the content of all the aforementioned documents indicates that C. S.A. was also aware of the erroneous organization of the DPO's work, which leaves no doubt about the intentional nature of the violation of the provisions of Regulation 2016/679. In the EROD Guidelines 04/2022, it is stated that "the intentional or unintentional nature of the violation (Article 83(2)(b) of the GDPR) should be assessed considering the objective elements of behavior collected based on the factual circumstances of the case." EROD emphasized that it is widely recognized that "intentional violations that show contempt for the law are more serious than unintentional ones." In the case of intentional violations, there is a likelihood that the supervisory authority will attribute greater weight to this factor.

c) Relevant previous violations of the provisions of Regulation 2016/679 by the administrator (Article 83(2)(e) of Regulation 2016/679) – when making a decision on the imposition and amount of an administrative fine, the supervisory authority is obliged to take into account any previous violations of Regulation 2016/679. EROD in Guidelines 04/2022 explicitly states: "The existence of previous violations can be considered an aggravating factor when calculating the amount of the fine. The weight attributed to this factor should be determined considering the nature and frequency of previous violations. However, the absence of previous violations cannot be considered a mitigating circumstance, as compliance with the provisions of [Regulation 2016/679] is the norm." And although, as indicated in the aforementioned guidelines, "greater significance should be attributed to violations concerning the same subject matter, as they are closer to the violation that is the subject of the current proceedings, especially when the administrator or processor has previously committed the same violation (repeated violations)" (point 88 of the guidelines), all previous violations can provide information about the overall approach of the administrator or processor to compliance with the provisions of Regulation 2016/679.

The supervisory authority has already established in previously issued administrative decisions that C. S.A. violated the following provisions on the protection of personal data: 1) in the decision of September 29, 2022 (ref. (...)), a violation of Article 6(1) of Regulation 2016/679, the President of the UODO issued a reprimand to C. S.A.; 2) in the decision of May 8, 2023 (ref. (...)), a violation of Article 15(1)(c) of Regulation 2016/679, the President of the UODO ordered C. S.A. to fulfill the information obligation; 3) in the decision of May 9, 2023 (ref. (...)), a violation of Article 15(1)(a) of Regulation 2016/679, the President of the UODO ordered C. S.A. to fulfill the information obligation; 4) in the decision of November 14, 2022 (ref. (...)), a violation of Article 15(1)(c) and Article 12(3) of Regulation 2016/679, the President of the UODO ordered C. S.A. to fulfill the information obligation and issued a reprimand; 5) in the decision of February 1, 2024 (ref. (...)), a violation of Article 6(1) of Regulation 2016/679, the President of the UODO issued a reprimand to C. S.A.; 6) in the decision of (...) (ref. (...)), a violation of Article 33(1) of Regulation 2016/679, the President of the UODO imposed an administrative fine on C. S.A. in the amount of (...) zlotys.

The aforementioned previous violations indicate a generally dismissive approach by C. S.A. to data protection issues, and the remedial measures previously applied to it in the aforementioned cases, including twice in May 2023 when the President of the UODO ordered C. S.A. to adjust its personal data processing operations to the provisions of Regulation 2016/679 due to violations of Article 15(1)(c) of Regulation 2016/679 and Article 15(1)(a) of Regulation 2016/679, or in connection with decisions issuing reprimands to C. S.A. for violations of Article 6(1) of Regulation 2016/679, as was the case in matters with reference numbers (...) and (...), fully justify the imposition of a financial sanction in this proceeding, as well as its amount.

It is also significant that the last decision for violating the provisions of Regulation 2016/679, in which the supervisory authority imposed an administrative fine on C. S.A., was issued on (...) and thus in a relatively short time preceding the issuance of this decision. This circumstance should be related to the content of Guidelines 04/2022, according to which "the moment when the previous violation occurred should be taken into account."

considering that the longer the time between this violation and the violation that is the subject of the

currently ongoing proceedings, the less significance the earlier violation holds. Consequently, the earlier the violation occurred, the less importance should be attributed to it by the supervisory authorities” (point 84 of the Guidelines). Thus, the above circumstance should influence the final decision of the supervisory authority and the amount of the imposed administrative monetary penalty. In light of the above, in this case, it should be recognized that there are grounds for treating the criterion in Article 83(2)(e) of Regulation 2016/679 as aggravating.

In deciding on the imposition of an administrative monetary penalty for the violation of Article 38(3) of Regulation 2016/679, the President of the UODO also took into account the following circumstance of the case, which has a mitigating effect on the amount of the imposed administrative monetary penalty:

- the degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679) – C. S.A. provided complete and specific explanations regarding its subject and the identified violations of personal data protection regulations during the inspection. Furthermore, following the inspection by the President of the UODO, C. S.A. took actions and measures aimed at improving compliance with Article 38(3) of Regulation 2016/679, in connection with the identified violation during the inspection. This was manifested in the establishment of the position of Data Protection Officer (DPO) within the organizational structure of C. S.A. and the amendment of the Organizational Regulations of C. S.A. (written explanations from C. S.A. dated November 29, 2023). For this reason, the degree of cooperation of C. S.A. with the supervisory authority in order to remedy the violation and mitigate its potential negative effects should be assessed as satisfactory, and thus it constitutes a mitigating factor in determining the amount of the administrative monetary penalty.

Other circumstances, indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the identified violation of Article 38(3) of Regulation 2016/679 in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty, namely:

- a) actions taken by C. S.A. to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679) – the evidence collected during the inspection and administrative proceedings indicates that the actions (or omissions) of C. S.A. did not cause any damage to the data subjects;
- b) the degree of responsibility of C. S.A. taking into account the technical and organizational measures implemented by it under Articles 25 and 32 of Regulation 2016/679 (Article 83(2)(d) of Regulation 2016/679) – the violation of Article 38(3) of Regulation 2016/679 is not related to the technical and organizational measures applied by C. S.A. as referred to in Articles 25 and 32 of Regulation 2016/679, therefore the criterion indicated in Article 83(2)(d) of Regulation 2016/679 does not have any aggravating or mitigating effect on the amount of the imposed administrative monetary penalty in this case;
- c) categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679) – due to the circumstance that the violation consisting of failing to ensure the independence of the data protection officer within the organizational structure of C. S.A. is not directly related to the violation of the protection of any personal data (and their categories), this criterion by its nature cannot be applied to the assessment of this violation;
- d) the manner in which the supervisory authority became aware of the violation, in particular, whether and to what extent the controller or processor reported the violation (Article 83(2)(h) of Regulation 2016/679) – the supervisory authority became aware of the violation of the provisions of Regulation 2016/679 as a result of conducting control activities. This fact should be assessed as neutral for the decision;
- e) if measures referred to in Article 58(2) have previously been applied to the controller in the same matter – compliance with these measures (Article 83(2)(i) of Regulation 2016/679) – prior to issuing this decision, the President of the UODO did not apply any measures referred to in Article 58(2) of Regulation 2016/679 to C. S.A. in the matter under consideration, which is why C. S.A. had no obligation to take any actions related to their implementation, and such actions, assessed by the supervisory authority, could have had an aggravating or mitigating effect on the assessment of the

identified violation;

f) the application of approved codes of conduct under Article 40 or approved certification mechanisms under Article 42 (Article 83(2)(j) of Regulation 2016/679) – as of the date of the decision, C. S.A. did not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for controllers, as stated in the provisions of Regulation 2016/679, which is why the circumstance of their non-application cannot be considered against C. S.A. in this case. On the other hand, the circumstance of adopting and applying such instruments could be taken into account in its favor as measures guaranteeing a higher than standard level of protection for personal data processing, however...

the nature of the violation and the circumstances of the case, the President of the UODO concluded that these factors did not affect the assessment of the violation or the amount of the imposed administrative fine.

IV.3. Conclusion on the amount of the administrative fine.

In light of the above considerations, the President of the UODO determined the amount of the administrative fine to be 200,000.00 EUR (equivalent to 873,060.00 PLN). This amount reflects the seriousness of the violation, taking into account the specific circumstances of the case, including the nature of the violation, the economic situation of C. S.A., and the absence of aggravating factors. The fine is intended to serve as a deterrent while being proportionate to the infringement and the financial capabilities of the entity involved.

The decision is based on the principles outlined in the General Data Protection Regulation (GDPR) and the guidelines provided by the European Data Protection Board (EDPB). The President of the UODO emphasizes the importance of compliance with data protection regulations and the need for entities to take appropriate measures to prevent future violations.

This decision is subject to appeal in accordance with applicable law.

Date: [Insert Date]

President of the UODO: [Insert Name]

the existence of one mitigating circumstance (the degree of cooperation to eliminate the violation) and one aggravating circumstance (appropriate previous violations), the President of the Personal Data Protection Office (UODO), assessing their overall impact on the evaluation of the violation, deemed it appropriate to further reduce the amount of the fine determined taking into account the turnover of C. S.A. (point 3 above); the appropriate reduction in light of the combined impact of both these circumstances on the assessment of the violation will be to the amount of 120,000.00 EUR (equivalent to 523,836.00 PLN). The President of UODO emphasizes that the most significant impact (mitigating) on this assessment was the removal of the violation by C. S.A. prior to the issuance of this decision; this fact should be highlighted and appreciated, as the primary goal of this proceeding and the remedial measures applied by the President of UODO is to bring C. S.A.'s processes of personal data processing into compliance with the law.

5) Despite the fact that the amount of the fine determined according to the above principles does not exceed the legally defined maximum, the President of UODO found that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty assessment (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a monetary penalty in the amount equivalent to 120,000.00 EUR would be effective (due to its severity, it would achieve its repressive goal of punishing unlawful behavior) and deterrent (allowing to effectively discourage both C. S.A. and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be, in the opinion of the President of UODO, disproportionate due to its excessive severity. The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case."

Therefore, considering the aspect of proportionality of the penalty, the President of UODO further reduced the amount of the penalty for the violation of Article 38(3) of Regulation 2016/679 – to 50% of the amount obtained after taking into account the aggravating and mitigating circumstances (see point 4 above), that is to the amount of 60,000.00 EUR (equivalent to 261,918.00 PLN). In his opinion, such a determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the amount of the penalty will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the penalty could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

IV.3. Violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 – criteria for the imposition of an administrative monetary penalty (Article 83(2) of Regulation 2016/679).

In deciding to impose an administrative monetary penalty for the violation by C. S.A. of the provisions of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679, the President of UODO imposed a single penalty due to the fact that the violation of both aforementioned provisions pertains to the same behavior of C. S.A. as the administrator, related to a single data processing operation, namely profiling. Thus, the President of UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have an aggravating effect on the assessment of the imposed administrative monetary penalty:

a) the nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679) – the violation of the provisions related to:

- the failure to include profiling operations in the description of processing activities contained in the register of processing activities maintained by C. S.A. (violation of Article 30(1) of Regulation 2016/679) and
- the failure to consider the impact of data processing activities involving profiling in the data protection impact assessment (violation of Article 35(1) and (7) of Regulation 2016/679),

is of significant weight due to the type of data processed by C. S.A. (e.g., data concerning the financial situation of the individuals concerned, PESEL number, etc.), the method of processing (use of IT systems, profiling), and the large scale of processing. Furthermore, the nature of the processing (profiling) is in this case an aggravating circumstance for C. S.A. due to the fact that the processing technique (automation, use of IT systems) and the specific risks to data subjects arising from the use of this technique require the administrator to exercise particular responsibility and sensitivity to data protection issues. Additionally, an aggravating circumstance is the profit-making nature of the processing, associated with C. S.A.'s pursuit of profit. From a data processor aiming to achieve economic benefits, and thus generally possessing significant financial and organizational resources, the requirements regarding the proper application of the organizational and security measures referred to in Regulation 2016/679 are higher, due to the greater technical, financial, and operational capabilities of such an entity. Profiling thus features a relatively high degree of reduction in the participation of...
of obtaining loans from non-bank institutions or fraudulently acquiring insurance or funds from insurance, which can lead to negative consequences related to attempts to harm the individuals whose data has been breached.”

d) the duration of the infringement (Article 83(2)(k) of Regulation 2016/679) – the infringement lasted for approximately 4.5 years, from January 15, 2019, until its rectification in August 2023. This prolonged duration of non-compliance indicates a significant oversight in the processing activities of C. S.A.

e) the degree of cooperation with the supervisory authority (Article 83(2)(l) of Regulation 2016/679) – C. S.A. has cooperated with the supervisory authority during the investigation process, providing

necessary documentation and explanations. However, the initial lack of awareness regarding the profiling operations and their implications reflects a need for improved compliance measures.

f) the categories of personal data affected by the infringement (Article 83(2)(g) of Regulation 2016/679) – the personal data processed by C. S.A. includes a wide range of categories, such as name, surname, residential and correspondence address, PESEL number, date of birth, email address, phone number, tax residency country, marital status, gender, number of children and their birth dates, identity document series and number, source of wealth, citizenship, employer's address, and credit obligations. Additionally, in the context of data obtained through profiling, C. S.A. processes data such as scoring results, which indicate credit risk assessment and risk category defined by C. S.A.

g) the nature of the personal data (Article 83(2)(h) of Regulation 2016/679) – while the PESEL number is not classified as sensitive data under Article 9(1) of Regulation 2016/679, its unauthorized disclosure, along with the name and surname that uniquely identify an individual, can significantly and negatively impact the protection of that individual's rights or freedoms.

h) the impact of the infringement on the rights and freedoms of data subjects (Article 83(2)(i) of Regulation 2016/679) – the unauthorized processing of personal data, particularly sensitive identifiers such as the PESEL number, can lead to identity theft or fraud, which poses a serious risk to the rights and freedoms of the affected individuals.

In conclusion, the infringement of Articles 30(1) and 35(1) and (7) of Regulation 2016/679 by C. S.A. was characterized by several aggravating factors, including the duration of the infringement, the nature and categories of personal data involved, and the potential impact on the rights and freedoms of data subjects. These factors collectively contribute to the determination of the administrative fine to be imposed on C. S.A.

attributing responsibility for committing such fraud to the persons concerned.” As indicated in the Guidelines 04/2022 (p. 22), “Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) of the GDPR), the GDPR explicitly specifies the types of data that are subject to special protection, and thus a more stringent response when imposing fines. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR, as well as data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the greater the number of such categories of data involved in the breach or the more sensitive the data, the more weight the supervisory authority may assign to this factor.”

It should therefore be recognized that the PESEL identification number, which is an eleven-digit numerical symbol uniquely identifying a natural person, containing, among other things, the date of birth and gender designation, and thus closely related to the private sphere of the individual and also subject to protection under Article 87 of Regulation 2016/679 as a national identification number, is data of a special nature and as such requires equally special protection.

In this case, the aforementioned circumstances are therefore aggravating for the decision and the imposition of a penalty because they relate to the issue of C. S.A.'s failure to include profiling operations in the processing activities register and in the assessment of processing impacts. In other words, the categories of data processed by C. S.A. had an impact on the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 and on the severity of this violation because, within the framework of profiling operations, they are significantly important for the broadly understood security of data and the risk of infringement of the rights or freedoms of data subjects. Therefore, the aforementioned criterion in this case should be considered as aggravating for the decision and the amount of the administrative monetary penalty imposed on C. S.A.

d) relevant previous violations of the provisions of Regulation 2016/679 by the controller (Article 83(2)(e) of Regulation 2016/679) – in relation to the aforementioned criterion, reference should be made to the arguments presented in point IV.1., regarding the allegation of violation of Article 38(3) of Regulation 2016/679.

In deciding to impose an administrative monetary penalty for the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679, the President of UODO took into account the following circumstance of the case, which mitigates the amount of the imposed administrative monetary penalty:

- the degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679) – C. S.A. provided complete and specific explanations during the inspection and additionally presented in the post-inspection explanations in writing first a plan of corrective actions and then their execution. C. S.A. submitted to the President of UODO a modified register of processing activities as well as a revised content of the prepared impact assessment. In both of the aforementioned documents, the operation of data processing in the form of profiling was separately and clearly included. Therefore, this circumstance should be considered as mitigating in this case.

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established violation of Article 38(3) of Regulation 2016/679, were considered by the President of UODO as neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty, namely:

- a) actions taken by C. S.A. to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679) – from the evidence collected during the inspection and administrative proceedings, it follows that the actions (omissions) of C. S.A. constituting a violation of the provisions of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 did not cause any damage to the data subjects;

- b) the degree of responsibility of C. S.A. taking into account the technical and organizational measures implemented by it under Articles 25 and 32 of Regulation 2016/679 (Article 83(2)(d)) – in relation to the aforementioned criterion, reference should be made to the arguments presented in point IV.1. above, regarding the allegation of violation of Article 38(3) of Regulation 2016/679;

- c) the manner in which the supervisory authority became aware of the violation, in particular, whether and to what extent the controller or processor reported the violation (Article 83(2)(h) of Regulation 2016/679) – in relation to the aforementioned criterion, reference should be made to the arguments presented in point IV.1. above, regarding the allegation of violation of Article 38(3) of Regulation 2016/679;

- d) if measures referred to in Article 58(2) were previously applied to the controller in the same case – compliance with these measures (Article 83(2)(i) of Regulation 2016/679) – in relation to the aforementioned criterion, reference should be made to the arguments presented in point IV.1. above, regarding the allegation of violation of Article 38(3) of Regulation 2016/679.

- e) the application of approved codes of conduct under Article 40 or approved certification mechanisms under Article 42 (Article 83(2)(j) of Regulation 2016/679) – with respect to the aforementioned premise, reference should be made to the arguments presented in point IV.1. above, regarding the allegation of violation of Article 38(3) of Regulation 2016/679.

- f) financial benefits obtained directly or indirectly in connection with the violation or losses avoided (Article 83(2)(k) of Regulation 2016/679) – with respect to the aforementioned premise, reference should be made to the arguments presented in point IV.1. above, regarding the allegation of violation of Article 38(3) of Regulation 2016/679.

- g) other aggravating or mitigating factors applicable to the circumstances of the case [Article 83(2)(k) of Regulation 2016/679] – The President of UODO, having comprehensively examined the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative fine.

IV.4. Violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 – determination of the amount of the administrative fine.

It is necessary to indicate that in determining the amount of the administrative fine for the violation of

Article 30(1) and Article 35(1) and (7) of Regulation 2016/679, the President of UODO applied the methodology adopted by EROD in Guidelines 04/2022. According to the guidelines presented in this document:

1) The President of UODO categorized the violations of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of Guidelines 04/2022). The violations of Articles 30(1) and 35(1) and (7) of Regulation 2016/679 belong – according to Article 83(4)(a) of Regulation 2016/679 – to the category of violations subject to a fine of up to 10,000,000 EUR or up to 2% of the total annual turnover of the enterprise from the previous financial year. It should therefore be stated that in light of the classification of violations of the provisions of Regulation 2016/679 adopted by the European legislator and the penalties provided in connection with them, the violation of the aforementioned provisions of Regulation 2016/679 belongs to those of lesser severity.

2) The President of UODO assessed the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 identified in this case as a violation of medium severity (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the factors among those listed in Article 83(2) of Regulation 2016/679 that relate to the subject matter of the violations (constituting the "severity" of the violation), namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679) were taken into account. A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violation identified in this case treated in its entirety leads to the conclusion that the level of its severity (understood in accordance with Guidelines 04/2022) is medium. Consequently, this results in the acceptance – as the starting amount for calculating the fine – of a value falling within the range of 10% to 20% of the maximum fine that can be imposed on C. S.A., that is – considering the limit specified in Article 83(4) of Regulation 2016/679 – from 1,000,000 EUR to 2,000,000 EUR (see Subchapter 4.2.4 of Guidelines 04/2022). The President of UODO considered the starting amount of 1,200,000.00 EUR (equivalent to 5,238,360.00 PLN) to be appropriate and justified in the circumstances of this case.

3) The President of UODO adjusted the starting amount, corresponding to the medium severity of the identified violation, to the turnover of C. S.A. as a measure of its size and economic strength (see Chapter 4.3 of Guidelines 04/2022). According to Guidelines 04/2022, in the case of enterprises whose annual turnover, as in this case, is between 50 and 100 million EUR, the supervisory authority may consider making further calculations of the fine based on a value falling within the range of 8% to 20% of the starting amount. Given that the turnover (revenue) of C. S.A. in the last financial year (from April 1, 2023, to March 31, 2024) amounted to 430,699,360.00 PLN, which is 98,664,320.89 EUR (according to the average EUR exchange rate on January 29, 2024), the President of UODO deemed it appropriate to adjust the amount subject to calculations to a value corresponding to 20% of the starting amount, that is to the amount of 240,000.00 EUR (equivalent to 1,047,672.00 PLN).

4) The President of UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the severity of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is to the entity itself that committed the violation and to its behavior before, during, and after the occurrence of the violation. A detailed assessment and justification of the impact of each of these factors on the assessment of the violation have been presented above. The factors referred to in Article 83(2)(c), (d), (h), (i), (j), (k) of Regulation 2016/679 – as indicated above – had no impact, either mitigating or aggravating, on the assessment of the violation and consequently on the imposition of the fine. Due to the existence in the case of one mitigating circumstance (degree of cooperation in order to rectify the violation) and one aggravating circumstance (previous relevant violations)

of violations) The President of the UODO, assessing their overall impact on the evaluation of the violation, deemed it appropriate to further reduce the amount of the fine determined with consideration of the turnover of C. S.A. (point 3 above); after taking into account the cumulative impact of both aforementioned circumstances on the assessment of the violation, the President of the UODO found it

appropriate to reduce it to the amount of 144,000.00 EUR (equivalent to 628,603.20 PLN). The President of the UODO emphasizes that the most significant (mitigating) factor influencing this assessment was the removal of the violation by C. S.A. prior to the issuance of this decision; this fact should be highlighted and appreciated, as the primary aim of these proceedings and the remedial measures employed by the President of the UODO is to bring the data processing processes of C. S.A. into compliance with the law.

5) The President of the UODO stated that the amount of the administrative monetary penalty determined in the manner presented above for the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the penalty provided for the most serious violation (see Chapter 6 of Guidelines 04/2022). Both violations – Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 – are subject to the same penalty, and therefore both should be assigned the same severity. As indicated above, they are subject to an administrative monetary penalty of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable. The President of the UODO determined that the "dynamic maximum amount" for this violation and for this violator expressed as a percentage (2%) of its turnover would amount to 1,973,286.42 EUR, which is why in this case the "static maximum amount" of 10,000,000 EUR should be applied for the examined violation. The aforementioned amount of 144,000 EUR obviously does not exceed the amount of 10,000,000 EUR.

6) Despite the fact that the amount of the penalty determined in accordance with the above principles does not exceed the legally defined maximum, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for penalty imposition (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a monetary penalty of 144,000 EUR would be an effective penalty (due to its severity, it would achieve its repressive goal of punishing unlawful behavior) and deterrent (effectively discouraging both C. S.A. and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a penalty would be – in the opinion of the President of the UODO – disproportionate due to its excessive severity. The principle of proportionality requires, among other things, that the measures adopted by the supervisory authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity determined by taking into account the circumstances of the specific case." Therefore, taking into account the proportionality of the penalty, the President of the UODO further reduced the amount of the penalty for the violation of Article 30(1) and Article 35(1) and (7) of Regulation 2016/679 – to 50% of the amount obtained after considering the aggravating and mitigating circumstances (see point 4 above), that is, to the amount of 72,000.00 EUR (equivalent to 314,302.00 PLN). In the opinion of the President of the UODO, such determination of the final amount of the imposed penalty will not affect its effectiveness and deterrent nature. This amount constitutes a threshold, above which further increases in the amount of the penalty will not be associated with an increase in its effectiveness and deterrent nature. On the other hand, a greater reduction in the amount of the penalty could occur at the expense of its effectiveness and deterrent nature, as well as the consistent application and enforcement of Regulation 2016/679 and the principle of equal treatment of entities in the EU and EEA internal market.

In deciding whether to impose an administrative monetary penalty and determining its amount, the President of the UODO considered the serious nature of the violation of the provisions of Regulation 2016/679, primarily Article 30(1) and Article 35(1) and (7) of Regulation 2016/679, due to the failure to take profiling into account in the description of the data processing processes (activities) contained in the register of processing activities maintained by C. S.A. and the failure to conduct a data protection impact assessment regarding the data processing activities involving profiling. The requirement to maintain a register of processing activities (Article 30(1) of Regulation 2016/679) and the requirement to conduct a data protection impact assessment (Article 35(1) of Regulation 2016/679) boils down to

taking into account in the aforementioned actions and documents the actual processes (operations) of processing occurring at a given administrator. C. S.A., by creating a register of processing activities and conducting an impact assessment, "buried" the profiling operation in the description of other processes (e.g., related to granting loans). Such an action is permissible in many cases (the so-called product approach to the content of the register and risk assessment), however, due to the specificity of profiling described above in the decision and the associated risks to the rights or freedoms of data subjects, such action was in this case inconsistent with the aforementioned provisions of Regulation 2016/679.

V. Summary.

In accordance with Article 103 of the Act of May 10, 2018 on the protection of personal data (Journal of Laws of 2019, item 1781), the equivalent of the amounts expressed in euros, the obligations imposed by the regulations, which is evidenced by the violations identified in this case.

The amounts of the administrative fines imposed on C. S.A. are intended to ensure compliance with the provisions of Regulation 2016/679 and to promote a culture of data protection within the organization. The fines are designed not only to penalize past violations but also to encourage future compliance and adherence to data protection laws.

In conclusion, the President of the Personal Data Protection Office has determined that the administrative fines imposed are appropriate and necessary to achieve the objectives of the regulation, ensuring that C. S.A. takes the necessary steps to rectify its practices and protect the personal data of its clients in accordance with the law.

obligation to appoint a DPO in a manner ensuring their direct subordination to the highest management of C. S.A. as the administrator, and also violated the obligation to maintain a register of processing activities and to conduct an assessment of the impact on processing in a diligent manner that transparently reflects the essence of data processing processes.

In the opinion of the President of the UODO, the administrative monetary penalties applied fulfill, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., they are effective, proportionate, and deterrent in this individual case. In this regard, it should be noted that the administrative monetary penalties in the total amount of 576,220.00 PLN meet the criteria referred to in Article 83(1) of Regulation 2016/679 due to the severity of the identified violation of the provisions of Regulation 2016/679.

In this factual and legal state, the President of the Personal Data Protection Office ruled as stated in the operative part.

[1] Guidelines of the Article 29 Working Party on Data Protection regarding Data Protection Officers ("DPO"), amended and adopted on April 5, 2017, p. 16.

[2] A. Mednis "The Law on Personal Data Protection in Relation to the Profiling of Natural Persons", Presscom sp. z o.o., Wrocław 2019, pp. 300-301.

[3] A. Mednis "The Law on Personal Data Protection in Relation to the Profiling of Natural Persons", Presscom sp. z o.o., Wrocław 2019, p. 292.

[4] (P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Personal Data Protection Act. Selected Sectoral Provisions. Commentary).

[5] P. Litwiński (ed.), Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Personal Data Protection Act. Selected Sectoral Provisions. Commentary.

Print article

Metadata

Provider:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-12-18

Information entered by:

Wioletta Golańska

2025-01-17 14:26:23

Last modified by:

Agnieszka Kaczor

2025-01-20 12:10:45